

90-Day Pilot Pre-Flight Checklist.

Two parallel lanes — customer-side configuration + Sparcle-side preparation — that must complete in the 30-day deployment window before the 60-day validation window begins. Maps directly to the Bolt and Aeira threat models.

① Pre-pilot · Two parallel lanes

☐ Customer-owned ☐ Sparcle-owned

Customer (your security + platform team)

- ☐ **IdP wiring.** Configure Okta / Entra / OneLogin / Auth0 / Google / Zoho — or any compliant OIDC / SAML 2.0 — with required claims: `tenant_id` · `user_id` · `region` · `office` · `role_band` · `department` · `employment_type` · `country` · `is_admin`. Backs Aeira §01 B4.
- ☐ **Per-tenant CMK provisioned** in Vault / AWS KMS / Azure Key Vault / PKCS#11 HSM. Decide HSM-backed for highest-assurance tenants. Backs Aeira §01 B5 + §03.
- ☐ **LLM endpoint chosen + contracted.** OpenAI Enterprise / Azure OpenAI / Bedrock / on-prem Llama / Mistral / Aleph Alpha. Confirm endpoint logging + replay policy with vendor.
- ☐ **Egress / network rules.** Allow-list Aeira API, LLM endpoint, and source-system endpoints; deny everything else. Confirm Absolute / Bundled tier has zero outbound to Sparcle.
- ☐ **Postgres hardened** per your DBA standard: at-rest encryption, restricted DB role, query logging if required. Aeira does not enforce Postgres-side controls.
- ☐ **Endpoint controls on user devices.** FileVault / BitLocker, MDM enrollment, code-signing enforcement. Threat model out-of-scopes physical compromise.
- ☐ **Bridge consent mode chosen.** Default vs. require-every-action — set tenant-wide. Backs Bolt §02.
- ☐ **Top-10 sources identified** for late-bind backfill priority (see Sparcle lane). Provide list of source ACL primitives Aeira must respect.
- ☐ **Pilot users defined** (8-20 ideal). Include at least one of each persona: executive, engineer, finance, HR, regional rep — to exercise the 4-axis ACL.
- ☐ **Security review window booked.** CISO / SecArch slot in week 2-3; threat-model walkthrough in week 4.
- ☐ **Procurement docs requested.** DPA template, MSA template, BAA (if PHI), source-code escrow agent decision (Iron Mountain / NCC Group).
- ☐ **Pen-test report shared** when Sparcle's external report lands (week 4 of deployment).

Sparcle (you'll see these completed)

- ☐ **Trial sidecar delivered** (signed binary, embedded Postgres, Contoso 2,573-row demo corpus). Customer can run before any infra work.
- ☐ **Helm chart / docker-compose tuned** for customer's VPC sizing. Production deployment artifacts in customer's internal registry.
- ☐ **Connector backfill** — `check_permissions()` implementations for the top-10 sources you identified. Today: 6 of 103 sources have it; 4-10 more land during pilot's week 1-2.
- ☐ **Per-tenant CMK rotation runbook** + your KMS adapter pre-configured.
- ☐ **End-to-end ingest saga wired** for the chosen connectors (~1-2 days from green-light).
- ☐ **Audit-verifier binary delivered** + walkthrough scheduled with your CISO team.
- ☐ **Threat-model documents** (Aeira + Bolt) reviewed with your SecArch in week 1-2.
- ☐ **External pen-test report** by HackerOne / Bishop Fox / NCC Group delivered in week 3-4 (if Sparcle hasn't booked one already, this is a contract trigger).
- ☐ **Pre-filled SIG Lite + CAIQ** handed over to your procurement at kickoff.
- ☐ **Tenant onboarding** — first 8-20 user accounts provisioned + persona assignments validated against ACL.
- ☐ **Compliance handbook + IR plan** handed over.
- ☐ **Source-code escrow agreement** executed with customer-selected agent.

Tier scope: This checklist applies to **Bolt Absolute** and **Bolt Bundled** tiers (customer-hosted; recommended for regulated workloads). **Bolt Complete** (Sparcle-managed hosting) requires a different pilot scope — see the compliance handbook §4.1 sub-processor table.

Timeline + Acceptance.

30-day deployment window + 60-day validation window = 90-day pilot. Validation cannot begin until Phase B sign-off; sign-off requires every deployment row complete.

② Phase A · Discovery + sign-on · Days -7 → 0

DISCOVERY	-7 → -3	Sparcle: deliver trial sidecar + demo screencast. Customer: stand up trial in dev VM, see Contoso ACL personas filter live. Joint: review the 10-artifact sales portfolio (leave-behind, CISO brief, TCO, architecture, compliance handbook, threat models, vertical brief).
SCOPE LOCK	-3 → -1	Joint: sign pilot MSA + DPA (plus BAA if PHI in scope, SCC if EU). Lock the connector list (top-10 + extended), pilot-user list, success criteria.
KICKOFF	Day 0	Joint kickoff call. Hand off the pre-filled SIG Lite / CAIQ. Schedule weekly Sparcle-side check-ins.

③ Phase B · Deployment · Days 1 → 30

INFRA	1 → 7	Customer: Helm chart or docker-compose deployed in VPC; per-tenant CMK provisioned; egress allow-list applied. Sparcle: tune sizing, complete top-10 connector backfills.
IDP + AUTH	5 → 10	Customer: IdP configured with the 9-claim contract. Joint: first SSO login test; verify JWT validation rejects malformed tokens with 401 + emits no audit event.
CONNECTORS	8 → 18	Joint: wire the chosen connectors (typically: SharePoint / Confluence / Slack / Jira / Salesforce / Workday / Snowflake / ServiceNow / GitHub / GDrive — depending on customer's primary data). Verify each connector's ACL semantics with a test document tagged for restriction.
AUDIT CHAIN	12 → 16	Customer security: run aeira-audit-verify binary on an audit-chain export. Confirm Ed25519 signatures validate against your KMS public key. Modify a byte, confirm verifier reports the break.
THREAT-MODEL WALKTHROUGH	15 → 22	Joint: CISO / SecArch reviews Bolt + Aeira threat models against the deployed system. Document any custom mitigations.
PEN-TEST LANDING	22 → 28	Sparcle: deliver external pen-test report (or accelerate-fund inside pilot). Customer: review with your security team.
PHASE B GATE	30	Joint sign-off: all Phase B rows complete. Sign the deployment-acceptance form on p.2. Validation cannot begin until this signs.

Validation + Sign-Off.

60-day validation window starts only after Phase B sign-off. Acceptance criteria define what "successful pilot" means.

④ Phase C · Validation · Days 31 → 90

USER ONBOARDING	31 → 38	8-20 pilot users on Bolt desktop + browser extension + PWA. Each onboarded against their assigned persona; ACL behavior validated per user.
WORKFLOW CAPTURE	38 → 60	Users run real cross-source workflows. Each user logs at least 5 multi-source workflows. Sparcle observes (via shared session export) and tunes connectors.
MEASUREMENT	55 → 80	Measure against acceptance criteria below. Time-on-task, query latency, ACL-correctness checks, audit-chain integrity samples.
GO-LIVE DECISION	81 → 90	Joint: review acceptance criteria. Decision: expand to production, extend pilot, or terminate. Reference-case slide drafted if expand.

Acceptance criteria — what "successful pilot" means

- ACL correctness.** Zero recorded incidents of a user retrieving a document outside their 4-axis ACL scope. Validated by structured test set + observed user activity.
- Audit-chain integrity.** Customer's verifier runs at week 4, 8, 12 — all three sample runs return chain-valid + signature-valid. Customer holds the chain export, not Sparcle.
- Latency.** p95 search latency under customer-defined SLA (typical: 250-500ms on 100K-doc corpus; benchmark published before pilot end).
- Connector reliability.** Each connector polls within its declared cadence; zero connector-side credential leaks; conformance harness green throughout.
- User adoption.** ≥70% of pilot users active in the final 2 weeks. ≥5 multi-source workflows logged per active user.
- No new sub-processors introduced.** Per Bolt Absolute / Bundled commitments. Validated in compliance handbook §4.1 review.
- Threat-model walkthrough sign-off.** CISO / SecArch confirms in writing that the deployed system matches the documented threat model + no critical residual risks remain unfunded.

Phase B (Deployment) acceptance — sign at Day 30

Customer security lead · printed name + role

Customer platform lead · printed name

Sparcle deployment lead · printed name + role

Date (YYYY-MM-DD)
